Incident Response Plan

Scenario: Phishing Email Leading to Unauthorized Access

1. Purpose

To establish a structured approach for detecting, analyzing, containing, and recovering from phishing incidents that may lead to unauthorized access and potential data leakage, while ensuring timely response and minimizing business impact.

2. Roles and Responsibilities

- **SOC Analyst**
  - Monitor alerts and identify phishing emails
  - Perform initial email and user activity analysis
  - Conduct detailed investigation (email, endpoints, sign-ins)
  - Perform containment and eradication actions
- **Firewall, Endpoint and Exchange Teams**
  - Implement blocking actions (IP, domains, URLs)
  - Delete emails
  - Support endpoint investigation and remediation
- **Management**
  - Oversee incident severity and business impact
  - Approve escalation and external communication

3. Detection and Analysis

Detection and investigation activities include:

- Identify phishing email details:
  - Sender email address, Recipient, Subject, URLs
  - Timestamp of email accessed
- Analyze user exposure:
  - Identify users who received the email
  - Check for mailbox delegation and forwarding rules
- Email analysis:
  - Phishing email header analysis to know true sender source
  - Record indicators of compromise (IOC) such as:

        - Source IP address
    - URL
    - File hash (if attachment present)
- User actions
    - Determine if the user:
        - Clicked on the link
        - Opened or downloaded any attachments
- Endpoint investigation:
    - Identify affected devices
    - Collect device IDs and perform forensic analysis
    - Capture logs (timestamps, IPs, user agents, app IDs)
- Authentication Analysis
    - Investigate suspicious sign-ins
    - Identify unauthorized access attempts

4. **Containment**

   Actions to limit the spread and impact:
   - Isolate affected endpoints identified during investigation
   - Block malicious IP addresses/URLs/domains.
   - Remove compromised users from affected systems (if required)
   - Disable suspicious forwarding or delegation rules

5. **Eradication**

   Steps to eliminate the threat:
   - Remove malicious emails from all affected mailboxes
   - Delete malicious files or payloads from all endpoints
   - Investigate and remediate compromised credentials
   - Address root cause (e.g., phishing vector, exploited link, attachment execution)

6. **Recovery**

   Restore normal operations securely:
   - Restore affected systems after validation
   - Re-enable user access after securing accounts
   - Monitor systems and accounts for any recurring suspicious activity
   - Ensure all indicators of compromise are cleared

7. Lessons Learned

Post-incident improvement actions:

- Document:
  - Attack vector (email, link, attachment)
  - Impact (unauthorized access, data exposure)
- Update:
  - Phishing detection rules
  - Email security controls
- Improve:
  - User awareness and training
  - Playbooks based on gaps identified
- Maintain records of:
  - Indicators of compromise
  - Incident timeline and response actions